Mobile Demo Script Explanation -- Reachingout (App Dev, Challenge 03)

Olawoyin Joseph Pamilerin, ISU520196

In one sentence: Echo the form's own hidden fields back verbatim alongside the computed answer -- the server rejects a bare answer.

Background -- what the terms below mean

What does "App Dev" mean, as a category? On this platform, **App Dev** challenges ask you to write your own small Android app that behaves a certain way. This is different from **Reversing** or **Exploitation** challenges, where you're given someone else's app to break into -- here there's usually no separate target app to download at all. You are writing code from scratch (or talking to a small server the challenge provides) to meet a spec.

What is an APK? The installable file for an Android app (like a .exe on Windows). For this category, the APK that matters is the one **you build and submit**, not a downloaded target.

What is logcat / the MOBISEC tag? Android apps can write messages to the phone's system log, called **logcat**. The grading harness watches for lines tagged **MOBISEC** and checks their content to decide whether to accept the submission.

How the APK was obtained

This one doesn't hand you a separate target APK to download at all. The challenge is to **write your own small app** that satisfies a spec (often by talking to a small server the platform runs, or to another running app component). So the only APK in play here is the one **you** build and submit -- there's nothing to decompile.

How the solution was built

Built as a normal **Android Studio project** (Gradle). From a terminal: `cd` into its `Android Studio Project` folder and run `gradlew.bat assembleDebug`. The resulting APK is kept right there as **SUBMITTED APK Challenge 03 Reachingout.apk**, ready to re-upload.

The vulnerability / technique, in plain terms

An HTTP server on `10.0.2.2:31337` (the emulator's alias for the grading harness's own host) serves the flag behind a two-step form. Submission #81997 revealed the root page is just a pointer ("You can get the flag here", linking to /flag); submission #81999 then revealed /flag serves an HTML <form> with the math question as visible text plus the exact operands as hidden fields (val1, oper, val2) that must be echoed straight back alongside the computed answer -- a bare "answer=9" POST was rejected as malformed. The app was rewritten to parse the page's own <form action=... method=...> tag and every hidden field directly out of the HTML, submitting all of them together with the computed answer to the form's own action URL -- submission #82002 confirmed this works.

Files to open

1. MainActivity.java:

```
C:\Users\Admin\Desktop\MOBISEC Challenge\Challenges\App Dev/03 Reachingout\Android Studio Project\app\src\ma
```

This is our own code -- open directly in Android Studio or any text editor.

What to say -- explanation of the exploit, step by step

1. I found that 10.0.2.2:31337 is the emulator's alias for the grading harness's own host machine.

2. I had my app perform an HTTP GET to that address and log the raw response.

3. My first submission (#81997) showed the root page has no math expression -- it just points to /flag via an anchor link.

4. I rewrote the app to follow any href link it finds, then a second submission (#81999) reached /flag and showed a real HTML form with hidden val1/oper/val2 fields.

5. That submission also showed a bare "answer=9" POST gets rejected as malformed, so I rewrote the app to parse the form's own action/method and every hidden field, and submit all of them together with the computed answer.

6. A third submission (#82002) confirmed this works: the server replied "Correct! Here is the flag: MOBISEC{...}".

If an emulator isn't available

If asked how you got/confirmed the flag: "I built my exploit app and uploaded the APK to the platform's own submission page. Their server ran it automatically against the target and returned the flag in the analysis log." This is backed by a real screenshot of that exact submission page (see **Real Screenshot: Live Platform Submission Page** in this challenge's Report.pdf), not just a claim -- worth pointing to directly if an emulator isn't running.

Result

The flag this challenge produced:

```
MOBISEC{I_was_told_by_liars_that_http_queries_were_easy}
```

Source: Verbatim from /apk/82002 analysis log

The real, verbatim output this run produced:

```
GET http://10.0.2.2:31337/flag response: How much is 3 + 6?
  <form action="/flag" method="POST">
    <input id="answer" name="answer" required type="text" value="">
    <input id="val1" name="val1" type="hidden" value="3">
    <input id="oper" name="oper" type="hidden" value="+">
    <input id="val2" name="val2" type="hidden" value="6">
    <input type="submit" value="Get Flag">
  </form>
parsed expression at http://10.0.2.2:31337/flag: 3 + 6 = 9
submitting form at http://10.0.2.2:31337/flag via POST with body: val1=3&oper=%2B&val2=6&answer=9
POST http://10.0.2.2:31337/flag (val1=3&oper=%2B&val2=6&answer=9) -> Correct! Here is the flag: MOBISEC{I_wa
FLAG: MOBISEC{I_was_told_by_liars_that_http_queries_were_easy}
```